

Incident Report

MySQL Database Ransomware – corp-pc-a32014

Analyst: Brian Utley

Date written: 10/6/2026

Status: Draft for review

1. Executive Summary

On 1 Oct 2026 the Azure-hosted Windows endpoint corp-pc-a32014 (local IP 10.2.0.23) suffered a successful network logon as local Administrator followed by unauthorized MySQL activity. An attacker enumerated and dumped data from the sm_corp database, dropped multiple databases (including sm_corp), and left a ransomware note demanding 0.0099 BTC inside a newly created RECOVER_YOUR_DATA database. The host continues to receive internet-sourced RDP and authentication attempts. No evidence of file-system encryption was observed in the supplied logs.

2. Incident Details

Detection window: First malicious MySQL activity ~19:59–23:05 1 Oct 2026 (MySQL audit); first successful attacker OS logon 22:48 1 Oct 2026.

Reporter: SOC (analysis of Defender Advanced Hunting + MySQL audit exports).

Classification: Ransomware / Unauthorized Database Access & Destruction – High severity.

Affected asset: corp-pc-a32014 (DeviceId ada46642e8721edc3393901e887f744a187af02b), Azure VM running Windows + MySQL, exposed RDP (3389) and MySQL.

KQL DeviceLogonEvents

```
let MyDevice = "corp-pc-a32014";  
  
let defaulttime = datetime(2026-10-02T00:45:15.4042327Z);  
  
DeviceLogonEvents  
| where TimeGenerated >= defaulttime  
| where DeviceName == MyDevice  
| where AccountName == "administrator" and ActionType contains "success"  
| project Timestamp, RemoteIP, ActionType, AccountName
```

```

11 let MyDevice = "corp-pc-a32014";
12 let defaulttime = datetime(2026-10-02T00:45:15.4042327Z);
13 DeviceLogonEvents
14 | where TimeGenerated >= defaulttime
15 | where DeviceName == MyDevice
16 | where AccountName == "administrator" and ActionType contains "success"
17 | project Timestamp, RemoteIP, ActionType, AccountName

```

Results Query history Getting started

Export Link to incident Take actions Show empty columns

Filters: Add filter

Timestamp	RemoteIP	ActionType	AccountName
Oct 1, 2026 10:48:34 PM		LogonSuccess	administrator
Oct 1, 2026 10:48:34 PM	200.9.155.148	LogonSuccess	administrator
Timestamp Oct 1, 2026 10:48:34 PM			
RemoteIP 200.9.155.148			
ActionType LogonSuccess			
AccountName administrator			
Oct 2, 2026 11:16:14 AM		LogonSuccess	administrator
Oct 2, 2026 11:16:14 AM	59.15.116.99	LogonSuccess	administrator
Timestamp Oct 2, 2026 11:16:14 AM			
RemoteIP 59.15.116.99			
ActionType LogonSuccess			
AccountName administrator			

3. Impact Assessment

Confidentiality: SELECT * FROM sm_corp.orders executed multiple times – data exfiltration likely.

Integrity / Availability: DROP DATABASE sm_corp, sakila, world (and temporary drop of the ransom DB itself). Business data in sm_corp is destroyed unless restored from backup.

Scope: Single host / single MySQL instance. No lateral movement or additional hosts observed in the provided data.

Business impact: Loss of production order data; ransom demand of 0.0099 BTC; continued exposure.

4. Indicators of Compromise

Type	Value	Source
BTC address	bc1qt6kstjjdatqnx3ksdcfv0jnhdjzndcnkx8zla	MySQL INSERT into RECOVER_YOUR_DATA
Contact email	ak+23u9y@onionmail.org	MySQL INSERT
Reference URL	https://cuq.in/844	MySQL INSERT
DATAID	23U9Y	MySQL INSERT
Ransom amount	0.0099 bitcoin	MySQL INSERT
Attacker IP	200.9.155.148	DeviceLogonEvents (LogonSuccess)
Attacker IP	59.15.116.99	DeviceLogonEvents (LogonSuccess)
DB name	RECOVER_YOUR_DATA	MySQL audit (repeated CREATE)
Privileged account	root@% (GRANT ALL / CREATE,DROP)	MySQL audit

KQL IoC

MySQLAudit_CL

```
| where RawData has_any ("RECOVER_YOUR_DATA","bc1qt6kstjjdatqnx3ksdcfv0jnhdjzndcnkx8zla","ak+23u9y@onionmail.org","DROP DATABASE")
```

```
| project TimeGenerated, RawData
```

1	MySQLAudit_CL
2	where RawData has_any ("RECOVER_YOUR_DATA","bc1qt6kstjddatqnxdk5dcfvejnhdjzndcnkx82ia","ak+23u9y@onionmail.org","DROP DATABASE")
3	project TimeGenerated, RawData

Results	Query history	Getting started
---------	---------------	-----------------

Export	Show empty columns	22 Items	Search	00:01.425	Low
--------	--------------------	----------	--------	-----------	-----

Filters:	Add filter
----------	------------

☐	TimeGenerated	☐	RawData
--------------------------	---------------	--------------------------	---------

☐	>	Oct 6, 2026 4:49:2...	2026-10-06T21:49:21.543616Z	37 Query	CREATE DATABASE IF NOT EXISTS RECOVER_YOUR_DATA
☐	>	Oct 6, 2026 10:49:...	2026-10-06T15:49:16.069625Z	81 Query	CREATE TABLE IF NOT EXISTS RECOVER_YOUR_DATA (text VARCHAR(255))
☐	>	Oct 6, 2026 10:49:...	2026-10-06T15:49:16.190327Z	81 Query	INSERT INTO RECOVER_YOUR_DATA (text) VALUES ('All your data was backed up by us. You must pay 0.0098 bitcoin to bc1qt6kstjddatqnxdk5dcfvejnhdjzndcnkx82ia or in 48 hours, your data will be publicly disclo
☐	>	Oct 6, 2026 10:49:...	2026-10-06T15:49:16.284911Z	81 Query	INSERT INTO RECOVER_YOUR_DATA (text) VALUES (' (for more information visit https://cuq.in/844) After payment send mail to ak+2ww55@onionmail.org and we will provide a link for you to download your data,
☐	>	Oct 6, 2026 10:49:...	2026-10-06T15:49:16.849638Z	88 Query	DROP DATABASE 'imp_corp_127'
☐	>	Oct 6, 2026 10:49:...	2026-10-06T15:49:17.397200Z	88 Query	DROP DATABASE 'sakila'
☐	>	Oct 6, 2026 10:49:...	2026-10-06T15:49:17.842799Z	88 Query	DROP DATABASE 'world'

5. Timeline

Time (approx)	Event	Source
1 Oct ~19:59	Multiple select * FROM sm_corp.orders + SHOW INDEX	mysqldata.csv
1 Oct 21:11	GRANT ALL PRIVILEGES ON *.* TO 'root'@'%' WITH GRANT OPTION	mysqldata.csv
1 Oct 22:16–22:33	~40 failed Network logons as administrator from 200.9.155.148	DeviceLogonEvents
1 Oct 22:48	Successful Network logon as administrator from 200.9.155.148	DeviceLogonEvents
1 Oct 23:04	CREATE DATABASE/TABLE RECOVER_YOUR_DATA; INSERT ransom notes (BTC + email + DATAID)	mysqldata.csv
1 Oct 23:04	GRANT CREATE, DROP ON *.* TO root'@'%'	mysqldata.csv
1 Oct 23:05	DROP DATABASE sm_corp, sakila, world, recover_your_data; re-CREATE + re-INSERT notes; GRANT SHUTDOWN / REVOKE	mysqldata.csv
2 Oct 00:25 onward	Repeated CREATE DATABASE IF NOT EXISTS RECOVER_YOUR_DATA (multiple days)	mysqldata.csv
2 Oct 11:16	Successful Network logon as administrator from 59.15.116.99	DeviceLogonEvents
Ongoing	High volume of inbound ConnectionAttempts to 3389 and other ports from internet IPs	DeviceNetworkEvents

KQL timeline
union DeviceLogonEvents, MySQLAudit_CL

| where DeviceName == "corp-pc-a32014"
| where Timestamp between (datetime(2026-10-01) .. datetime(2026-10-06))
| project Timestamp, ActionType, RawData, RemoteIP, AccountName
| order by RemoteIP desc

```

union DeviceLogonEvents, MySQLAudit_CL
| where DeviceName == "corp-pc-a32014"
| where Timestamp between (datetime(2026-10-01) .. datetime(2026-10-06))
| project Timestamp, ActionType, RawData, RemoteIP, AccountName
| order by RemoteIP desc

```

Results Query history Getting started

Timeline visualization

Export Show empty columns

ActionType: LogonSuccess Add filter Reset all

Timestamp	ActionType	RawData	RemoteIP	AccountName
> Oct 2, 2026 11:16:...	LogonSuccess		59.15.116.99	administrator
> Oct 1, 2026 10:48:...	LogonSuccess		200.9.155.148	administrator

6. Root Cause / Attack Vector

- Host was internet-exposed on RDP (3389) and MySQL.
- Brute-force Network logons against local Administrator succeeded from 200.9.155.148.
- Once on the host (or via direct MySQL access), the attacker obtained/used root@% privileges, dumped sm_corp.orders, dropped databases, and planted the ransom note.
- Exact initial MySQL authentication vector (weak password, exposed 3306, or post-OS-compromise) is **Not determined from available logs**. No evidence of exploit against JSON_SCHEMA_VALID beyond a long-string probe.

7. Response Actions

Containment

- Immediately block inbound 3389/3306 at NSG / Azure Firewall; restrict to jump-host or VPN only.
- Disable or rename local Administrator; force password reset.
- Quarantine the VM or isolate its NIC.

Eradication

- Drop any remaining RECOVER_YOUR_DATA database and revoke excessive GRANTs on root@%.
- Rotate all MySQL and Windows credentials.
- Review and remove any unauthorized accounts or scheduled tasks (none observed in supplied process/registry data).

Recovery

- Restore sm_corp (and any other dropped DBs) from the most recent clean backup taken before 1 Oct 19:59.
- Validate data integrity and re-enable application connectivity only after exposure is closed.

8. Evidence

- DeviceLogonEvents.csv – successful/failed Administrator Network logons.
- mysqlaudit.csv – SELECT on sm_corp.orders, GRANT statements, CREATE/INSERT of RECOVER_YOUR_DATA, DROP DATABASE statements.
- DeviceNetworkEvents.csv – persistent inbound SYN to 3389.
- DeviceProcessEvents / DeviceFileEvents / DeviceRegistryEvents – no clear OS-level ransomware artifacts observed in the supplied extracts.
- NTANetAnalytics.csv – outbound 80/443 only (no anomalous C2 volumes).

9. Lessons Learned / Recommendations

1. **Immediately** remove public RDP/MySQL exposure; enforce Just-in-Time access or private endpoints.
2. Enforce MFA / disable local Administrator for Network logons; implement account lockout.
3. Enable and alert on MySQL audit events for GRANT, DROP DATABASE, CREATE DATABASE matching "RECOVER*".
4. Ensure automated, immutable backups of critical databases with retention that covers the observed dwell time.
5. Hunt historically for the BTC address, onionmail address, and DATAID 23U9Y across all MySQL instances and email gateways.
6. Review Azure NSG / public IP assignments for all VMs running database services.

1. Baseline determination

I treated PreBreach_MDE_Investigation_Package as the baseline and PostBreachMDE_Investigation_Package as the comparison set.

- Baseline collection was at 2026-10-02T02:19:26Z and the post collection at 2026-10-06T21:49:47Z. Both come from the Forensics Collection Summary.csv command timestamps.
- Boot times agree: SystemInformation.txt shows 10/1 22:44:28 for baseline and 10/6 21:47:50 for post.
- The Security.evtx records are consistent with that order. Baseline covers 10/1 17:40 to 10/2 02:19. Post covers 10/5 23:40 to 10/6 21:49.
- Both packages are the same host (Corp-PC-A32014, Windows 11 build 26200, Azure VM, same SIDs).

2. Summary verdict

Compromise indicators: INCONCLUSIVE, leaning no successful compromise visible. Active attack confirmed. Confidence: moderate.

The post package holds a large external credential-guessing campaign (28,149 failed network logons) with no successful external logon and no persistence, new services, tasks or accounts in the visible window. But the Security log was flooded so that everything from 10/2 02:19 to 10/5 23:40 was overwritten, so a later success cannot be ruled out.

3. Notable deltas

Category	Item	Change	Assessment	Evidence
Event logs	28,149 Event 4625 failures, all logon type 3, NTLM	ADDED	Suspicious (brute force)	post Security.evtx, 10/5 23:40:49 to 10/6 02:24:17
Event logs	16 Event 4740 lockouts of administrator, about every 10 min (23:47:53 to 02:19:29)	ADDED	Suspicious (attacker retrying after each unlock)	post Security.evtx
Event logs	Log coverage: collector asked for events since 9/29, earliest record is 10/5 23:40	CHANGED	Suspicious (evidence loss by overwrite, not clearing)	evtx is 21,041,152 bytes in both packages (size cap); no Event 1102 in either
Event logs	No events 10/6 02:29 to 21:47	Gap	Likely VM stop and restart (inference)	post Security.evtx

Users/groups	administrator (RID 1000) created, in Users and Remote Desktop Users; Guest enabled, password set, in Users and Remote Desktop Users; Guest granted remote-logon right and denied-logon right removed	In baseline, unchanged in post	Needs verification (authorized by bult but a real exposure)	pre Events 4720, 4722, 4724, 4732, 4717, 4718, 10/2 02:02 to 02:09; both LocalGroups.txt
Users/groups	Administrators group contains only bult	UNCHANGED	Benign	LocalGroups.txt (pre and post identical)
Sessions	bult RDP session active in baseline, none in post	REMOVED	Benign (reboot)	QueryUser.txt
Network	Listeners 3389, 445, 135, 3306, 33060 on 0.0.0.0	UNCHANGED	Exposure	both ActiveNetConnections.txt
Network	UDP 500/4500 new; 7680 and loopback 28230 gone	CHANGED	Benign (post-reboot service start)	ActiveNetConnections.txt
Network	Outbound connections	CHANGED	Benign (Microsoft and Azure addresses only)	ActiveNetConnections.txt
DNS cache	azpdesfavyj6.stretchoid.com	REMOVED (baseline only)	Low (scanner reconnaissance); cache flushed by reboot	pre DnsCache.txt
DNS cache	Post entries	ADDED	Benign (Microsoft/Windows Update hosts only)	post DnsCache.txt
Processes	About 74 fewer, no new process names	REMOVED	Benign (post-reboot, no user session)	Processes.csv
Services/drivers	17 per-user _52dc9 services gone; Edge elevation service 154.0.4258.48 to .53; no new services	CHANGED	Benign	Services.csv
Scheduled tasks	No new tasks; SetupCleanupTask gone; OneDrive launcher path updated	CHANGED	Benign	ScheduledTasks.csv

Autoruns	About 200 added and 320 removed lines (Edge version strings, per-user service keys, BAM entries)	CHANGED	Benign; no new Run keys or startup items	Autoruns.txt
Installed programs	OneDrive per-user uninstall entry gone; Edge 154.0.4258.48 to .53	CHANGED	Benign	InstalledPrograms.csv
Prefetch	46 added, including AUDITPOL.EXE, MMC.EXE-64C25D5D, WERFAULT.EXE, SECURITYHEALTHSE TUP.EXE, Defender update binaries	ADDED	Mostly benign; auditpol and mmc are unexplained (see section 4)	Prefetch Files/Prefetch/
Temp (bult)	Six wct*.tmp files, plus one 147 MB (dated 9/26, before the 10/1 OS install) and one 5.8 MB	ADDED	Unexplained	post bult_TempDirFiles.txt
System info	App Control user-mode policy Audit to Off	CHANGED	Low, unclear (policy state at boot)	SystemInformation.txt
Defender	MAPS cloud check succeeded, then failed (hr=0x80072efd, HTTP 451)	CHANGED	Low	MpCmdRunLog.txt
Firewall, ARP, IP config	Only collector paths, interface index and DHCP lease changed	CHANGED	Benign	diffs

Prefetch timestamps could not be read (the PrefetchFilesList.txt files are robocopy logs), so the new prefetch entries are undated.

4. Strongest compromise indicators (ATT&CK)

- Brute force of remote logon (T1110.001/.003, Initial Access / Credential Access).
 - 62.238.86.212 produced 27,278 of the 28,149 failures. The other sources were 94.26.68.55, 197.13.40.33, 135.125.90.97, 212.11.39.27, 124.158.13.212, 85.211.176.151 and 86.92.53.191.
 - Usernames tried were ADMINISTRATOR (14,092), USER (4,636), ADMIN (4,635), SERVER (4,563), HP, PC, Administrator and AZUREUSER.
 - Only 160 attempts reached a password check (status 0xc000006d/0xc000006a), all against administrator. This means the lockout policy stopped almost all of the attack.
 - There is no 4624 type 3 or 10 from any external IP in the visible window.
- Defense impairment by log flooding (T1070, Defense Evasion). The flood pushed 10/2 to 10/5 out of the Security log. I can't tell from the package whether that was intentional or just a side effect of the volume.

3. Pre-existing weakness (T1078.001/.003). Guest is enabled and in Remote Desktop Users, a decoy-style administrator account exists, and 3389/445/3306/33060 listen on all interfaces. If any of that was unauthorized, it is persistence and privilege abuse by bult's session; a legitimate administrator is more likely, but confirm with them.
4. Unexplained artifacts (low). The new AUDITPOL.EXE prefetch could indicate someone checking or changing audit policy (T1562.002). The large wct*.tmp file and the new MMC.EXE prefetch are also unexplained. I found no Event 4719 audit-policy change in post to support the auditpol concern.

5. Probable incident type

Internet-exposed RDP/SMB credential brute-force or password-spray attempt against a decoy-style administrator account, with no confirmed successful access. Evidence of post-compromise activity (ransomware, exfiltration, persistence) is absent.

6. Gaps

- Security log: about 3.5 days (10/2 02:19 to 10/5 23:40) are missing, and 10/6 02:29 to 21:47 has no events. A successful logon in that window would be invisible.
- Other logs: no System, Application or PowerShell logs, and no process-creation audit beyond boot (Event 4688).
- Missing artifacts: no hosts file, no firewall rule dump (only collector commands in the firewall log), and no browser or credential artifacts. MPSSupportFiles.cab in both packages was not unpacked.
- Not checked: file hashes, signatures and loaded modules (not in these packages), and whether 3389/445 are reachable from the internet (NSG data needed).
- Prefetch: it cannot be dated or attributed to a user.
- IOC hunt: the attacker IPs appear 0 times in the baseline and only in post Security.evtx.